

Felipe Amorim Soria

Che cos'è il phishing?

Il **phishing** è un tipo di truffa digitale in cui i **criminali informatici cercano di ingannare la vittima affinché fornisca informazioni sensibili**, come password, dati bancari, numeri di carte di credito o credenziali di accesso. Il nome deriva dall'inglese "**fishing**" (pescare), perché il truffatore sta "pescando" dati, sperando che qualcuno abbocchi all'amo.

Come funziona il phishing:

L'attaccante si finge una persona, azienda o organizzazione affidabile. L'approccio può avvenire tramite:

- **E-mail false**, con link malevoli o allegati infetti.
 - **Messaggi SMS (smishing)** WhatsApp.
 - **Telefonate (vishing)**.
 - **Siti falsi** che imitano quelli reali per rubare credenziali e dati.
-

Esempio classico:

Ricevi un'e-mail apparentemente dalla tua banca che ti informa di un tentativo di accesso sospetto al tuo conto. Ti viene chiesto di cliccare su un link per "verificare la tua identità". Il link porta a un sito molto simile a quello ufficiale, dove inserisci i tuoi dati — che finiscono direttamente nelle mani dei criminali.

Come un attacco di phishing può compromettere la sicurezza di un'azienda

Un attacco di phishing può compromettere gravemente la sicurezza di un'azienda perché prende di mira **l'anello più debole della catena di sicurezza informatica: le persone**. Quando un dipendente cade nella trappola, può aprire la porta a vari tipi di attacchi informatici con conseguenze gravi.

Principali modalità di compromissione:

1. Furto di credenziali

L'attaccante ottiene username e password di sistemi interni (e-mail, ERP, CRM, conti bancari).

Può accedere a informazioni riservate, contratti, dati di clienti o segreti industriali.

2. Installazione di malware o ransomware

Il dipendente clicca su un allegato malevolo → il computer viene infettato.

Il ransomware cripta i dati e richiede un riscatto economico.

Può bloccare completamente le operazioni aziendali.

3. Accesso laterale e scalata dei privilegi

Con le credenziali ottenute, l'attaccante si muove all'interno della rete e accede a dati più critici. Può assumere il controllo degli account degli amministratori di sistema (il cosiddetto "movimento laterale").

4. Ingegneria sociale interna

Con l'accesso all'e-mail di un dipendente, il criminale può:

- Inviare messaggi a nome suo.
- Ingannare altri colleghi per ottenere altri accessi.
- Mettere in atto truffe finanziarie (es. richiedere trasferimenti fingendosi un dirigente).

5. Fuga di dati e violazioni normative (compliance)

Se l'azienda gestisce dati sensibili (clienti, sanità, finanza), una fuga di dati può violare normative come:

- **LGPD** (Brasile)
- **GDPR** (Europa)
- **HIPAA** (Stati Uniti)

Questo può comportare **multe, cause legali e danni alla reputazione**.

Esempio – Falsa e-mail della banca

Oggetto: ⚠ Il tuo conto è stato temporaneamente sospeso

Caro cliente,

Abbiamo rilevato un'attività insolita sul tuo conto.

Per garantire la tua sicurezza, il tuo conto è stato temporaneamente sospeso.

✅ Clicca sul link qui sotto per verificare i tuoi dati:

www.tuabanca-sicurezza.com

Cordiali saluti,

Team Sicurezza Banca XYZ

Piano di Remediation per Attacco di Phishing via E-mail

1. Pianificazione della Remediation

- **Identificazione e blocco delle e-mail fraudolente**
 - Analizza i messaggi ricevuti per isolare i mittenti e i domini sospetti.
 - Aggiorna i filtri del server di posta elettronica per bloccare ulteriori invii simili.
 - Inoltra le e-mail sospette ai team di sicurezza o fornitori di soluzioni anti-spam.
 - **Comunicazione interna ai dipendenti**
 - Invia un avviso a tutto il personale descrivendo l'attacco in corso.
 - Fornisci istruzioni chiare su cosa fare (es. non cliccare su link, segnalare e-mail, ecc.).
 - Crea un canale diretto per la segnalazione di nuovi tentativi.
 - **Verifica e monitoraggio dei sistemi**
 - Controlla i log di accesso e di rete per individuare attività sospette.
 - Verifica eventuali accessi non autorizzati con le credenziali rubate.
 - Isola i dispositivi compromessi, se presenti.
-

2. Implementazione della Remediation

Azioni pratiche per mitigare il danno e prevenire ulteriori attacchi:

- **Implementazione di soluzioni di sicurezza avanzate**
 - Attiva filtri anti-phishing (SPF, DKIM, DMARC).
 - Utilizza soluzioni di sicurezza per e-mail con rilevamento comportamentale.
 - **Formazione dei dipendenti**
 - Avvia un programma regolare di sensibilizzazione sulla sicurezza.
 - Insegna come riconoscere un'e-mail sospetta (linguaggio urgente, errori grammaticali, link strani, ecc.).
 - Promuovi la cultura della “**zero-trust**”: verificare sempre prima di agire.
 - **Aggiornamento delle policy di sicurezza aziendali**
 - Definisci chiaramente le azioni da intraprendere in caso di attacco.
 - Limita l'accesso alle informazioni sensibili solo al personale autorizzato.
 - Integra le policy con procedure di escalation e risposta agli incidenti.
-

3. Mitigazione dei Rischi Residuali

Per garantire la sicurezza a lungo termine:

- **Test di phishing simulati**
 - Organizza campagne regolari per valutare il comportamento reale dei dipendenti.
 - Usa i risultati per rafforzare le aree più vulnerabili.
- **Autenticazione a due fattori (2FA)**
 - Richiedi 2FA per l'accesso a tutti i sistemi critici e ai servizi cloud.
 - Integra soluzioni come app di autenticazione o chiavi hardware.
- **Aggiornamenti e patch regolari**
 - Mantieni tutti i sistemi operativi e software aggiornati.
 - Automatizza il patching per ridurre al minimo i tempi di esposizione.